

Phoros Onboarding and Recovery Architecture

1 Overview

Phoros onboarding should not be understood as ordinary account creation. A conventional application asks whether a user can log in. Phoros must answer a stronger set of questions: whether the account is controlled by the correct person, whether that person has been legally identity-proofed, whether the same biological person can later be recognized during high-risk events, whether the account is bound to a clinical identity, and whether the person has authority to exercise health-data rights.

The purpose of onboarding is therefore to create a staged, evidence-based identity binding. Each step contributes a different kind of evidence. No single step is treated as the whole identity.

2 Design Principle: Onboarding as Identity Binding

A Phoros account should be modeled as an evolving identity and authority graph, not as a single row in a user table. The system progressively binds together:

- a claimed person;
- verified communication channels;
- a legally identity-proofed person;
- one or more cryptographic account credentials;
- a Phoros-controlled biological-continuity reference;
- recovery and authority policies;
- one or more clinical identities or provider records.

This structure allows Phoros to distinguish between ordinary login, legal identity proofing, biological continuity, clinical record binding, and authority over health-data actions.

3 Separation of Identity Layers

The onboarding flow should explicitly separate the following layers.

Layer	Question Answered	Typical Evidence
Contact identity	Can Phoros reach this person through declared channels?	Email verification, phone verification, one-time passcodes.
Legal identity	Does this applicant correspond to government identity evidence?	Document verification, selfie-to-document match, database checks, external identity-proofing assertion.
Authenticator identity	Can this user control a cryptographic credential bound to the account?	Passkey, hardware-backed credential, device-bound authenticator.
Biological continuity	Is the same biological person present during high-risk account events?	Phoros liveness ceremony, biometric reference, continuity comparison.
Clinical identity	Does this person correspond to a patient identity at a provider or data source?	Provider attestation, EHR match, MRN binding, patient-mediated record authorization.
Authority identity	Who is allowed to exercise rights over this account and its health data?	Consent state, delegation records, caregiver authority, legal representative status, recovery policy.

The distinction is important because these layers can diverge. A person may control an email account but not the Phoros account. A caregiver may have delegated authority but is not the patient. A user may pass legal identity proofing but fail a biological-continuity check because of sensor failure, injury, aging, or model uncertainty. The system should represent these cases directly rather than collapse them into a binary verified/unverified state.

4 Primary Onboarding Flow

The primary onboarding flow should proceed in stages.

```

Phone; [step, right=of claim] (otp) Verify Email
and Phone; [step, right=of otp] (idv) Legal Identity
Proofing; [step, below=of idv] (passkey) Enroll
Passkey; [step, left=of passkey] (bio) Phoros Liveness
and Reference; [step, left=of bio] (recovery) Recovery
Policy; [step, below=of recovery] (active) Active Phoros
Account;
[arrow] (claim) – (otp); [arrow] (otp) – (idv); [arrow] (idv) – (passkey); [arrow] (passkey) – (bio);
[arrow] (bio) – (recovery); [arrow] (recovery) – (active);

```

A compact state-machine representation is:

PendingAccount → ContactVerified → LegalIdentityVerified → PasskeyBound → BiologicalContinuity

Clinical identity binding should be modeled as a subsequent but distinct step:

`ActivePhorosAccount` $\rightarrow$ `ClinicalIdentityLinked` $\rightarrow$ `RecordsImportAuthorized`.

A user can have an active Phoros account before any specific provider record has been connected.

Step 1: Claimed Identity and Contact Channels

The user initially provides a name, email address, and phone number. At this stage, Phoros has only a claimed identity and declared communication channels. The account should remain in a pending state.

The purpose of this step is not to establish legal or clinical identity. It only creates the initial onboarding object and permits Phoros to verify that the user controls the declared contact channels.

Step 2: Email and Phone Verification

The user verifies email and phone control, for example through six-digit one-time passcodes. This step establishes contact-channel control.

It should not be treated as sufficient for account authority. Email and phone control are useful for communication, notification, and low-risk account operations, but they are not sufficient for restoring control over a health-data account.

Step 3: Legal Identity Proofing

Legal identity proofing may be performed by Persona or a similar vendor. The vendor's role is to provide an external assertion that the applicant completed a legal identity verification workflow. Depending on the vendor and workflow, this may include document validation, selfie-to-document comparison, liveness, database checks, fraud checks, or related evidence.

The vendor should not become the root of Phoros identity. Instead, Phoros should store the result as a provenance-bound assertion:

- identity-proofing provider;
- timestamp;
- asserted attributes;
- workflow or assurance level;
- verification outcome;
- evidence type;
- expiration or reverification policy;
- relevant audit identifiers.

The conceptual meaning is:

The identity-proofing provider asserts that this live applicant matched the required legal identity evidence under a specified workflow at a specified time.

Phoros then incorporates that assertion into its own identity graph.

Step 4: Passkey Enrollment

After legal identity proofing succeeds, the user enrolls a passkey. The passkey establishes cryptographic account control.

The user-facing language should be precise. Phoros should not say that the user is “enrolling Face ID with Phoros.” A better description is:

Create a passkey using your device’s built-in security, such as Face ID, Touch ID, device PIN, or another platform authenticator.

Face ID or Touch ID unlocks the local device credential. Phoros does not receive Apple’s biometric template. The passkey proves control of a cryptographic authenticator. It does not, by itself, establish biological continuity.

Multiple passkeys should be encouraged. For example, a user may enroll a phone, laptop, and hardware security key. This reduces the likelihood that ordinary device loss becomes a high-risk recovery event.

Step 5: Phoros Liveness and Biometric Reference Enrollment

Phoros biological-continuity enrollment is distinct from vendor identity proofing and distinct from passkey enrollment.

The purpose of this step is to create a Phoros-controlled continuity reference that can later be used during high-risk account events. These events may include:

- lost-device recovery;
- passkey replacement;
- suspicious access;
- major data export;
- data transaction authorization;
- new caregiver delegation;
- clinical identity disputes;
- biological-continuity challenges.

The core question is not merely whether the user can log in. The core question is whether the same biological person who enrolled remains in control during sensitive events.

The biometric reference should be governed as highly sensitive data. Derived templates, embeddings, raw enrollment media, and liveness records may require different retention and access policies. In particular, raw biometric data should not be retained casually. If retained at all, it should be subject to explicit consent, strict retention limits, encryption, auditability, and deletion or replacement rules.

Step 6: Recovery Policy Setup

Recovery should be configured during onboarding, not treated as an afterthought. For Phoros, recovery is not merely password reset or passkey replacement. It is a governed process for restoring or transferring authority under uncertainty.

The user may configure:

- backup passkeys;
- recovery codes;
- trusted recovery contacts;
- provider-mediated recovery options;
- caregiver or legal representative preferences;
- escalation rules if biological continuity fails;
- notification preferences for sensitive recovery events.

The recovery policy should be represented as part of the identity and authority graph. It should be append-only or otherwise strongly auditable.

5 Infrastructure Components: IAM and Identity Proofing

The onboarding flow depends on two different categories of external or semi-external infrastructure. These categories should not be conflated.

1. **Identity and access management (IAM):** infrastructure for login, sessions, credentials, tokens, roles, and application access.
2. **Legal identity proofing:** infrastructure for verifying that the applicant corresponds to legal identity evidence.

The IAM layer helps answer whether an account can authenticate. The legal identity-proofing layer helps answer whether a live applicant has passed a specified legal identity verification workflow. Neither layer, by itself, defines Phoros identity, biological continuity, clinical identity, or authority over health data.

5.1 Keycloak and IAM Alternatives

Keycloak, or a similar IAM system, may be used as backend authentication infrastructure. Its role is to manage the mechanics of account access, not the meaning of Phoros identity.

Keycloak may support:

- login sessions;
- OAuth/OIDC flows;
- token issuance and validation;

- passkey or WebAuthn registration;
- service-to-service authentication;
- roles, groups, and realms;
- administrative access control.

In the onboarding flow, Keycloak is most directly relevant to passkey enrollment and subsequent login. It may help bind a cryptographic authenticator to a Phoros account and issue tokens after successful authentication.

However, Keycloak should not decide whether a user is legally verified, biologically continuous, clinically bound, or authorized to exercise health-data rights. Those decisions belong to the Phoros identity and authority layer.

The architectural boundary is:

Keycloak handles authentication mechanics. Phoros handles identity meaning, consent state, biological continuity, clinical binding, and authority.

Alternatives to Keycloak include Auth0, Stytn, FusionAuth, Ory, Zitadel, WorkOS, Ping, Okta, and a future Phoros-native authentication service. The choice should be treated as an implementation decision, not as the foundation of the Phoros identity model.

A useful internal abstraction is:

```
AuthenticationProvider
  -> provider_name
  -> account_identifier
  -> credential_type
  -> authenticator_id
  -> token_subject
  -> session_id
  -> authentication_time
  -> assurance_signals
```

This allows Phoros to change IAM vendors or eventually replace them without rewriting its identity graph, consent model, biological-continuity model, or clinical binding model.

5.2 Persona and Identity-Proofing Alternatives

Persona, or a similar identity-proofing vendor, may be used during onboarding to verify legal identity. The role of such a vendor is to provide an external identity assertion. It is not to become the root of Phoros identity.

A typical legal identity-proofing workflow may include:

- collection of government identity evidence;
- document authenticity checks;
- selfie-to-document comparison;
- liveness checks;

- database or fraud-risk checks;
- return of a verification decision and associated metadata.

The result should be stored as provenance-bound evidence in the Phoros identity graph. Phoros should record which vendor performed the check, what workflow was used, what attributes were asserted, when the verification occurred, and what assurance or risk signals were returned.

Alternatives to Persona include ID.me, Socure, Jumio, Entrust/Onfido, Veriff, Mitek, Trulioo, LexisNexis Risk Solutions, and future government or provider- mediated identity assertions.

These vendors differ in user experience and architecture. ID.me is closer to a reusable consumer identity-wallet model, where the user generally signs into or creates an ID.me account and then shares verified attributes with a relying party. Persona, Socure, Jumio, Entrust/Onfido, and similar vendors are more commonly used as embedded or hosted verification services inside another company’s onboarding flow. In that model, the user is primarily creating a Phoros account, while the vendor performs a verification step and returns an assertion.

For Phoros, the cleaner default is the embedded or hosted verification-service model:

The user is onboarding into Phoros. The vendor supplies legal identity evidence. Phoros remains the owner of the account, identity graph, consent state, biological-continuity layer, and authority model.

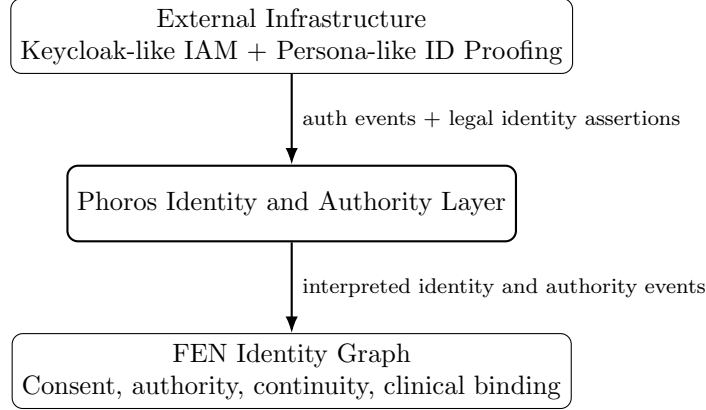
A useful internal abstraction is:

```
IdentityProofingProvider
-> provider_name
-> workflow_id
-> asserted_attributes
-> evidence_types
-> verification_result
-> assurance_level
-> risk_signals
-> timestamp
-> expiration_policy
-> audit_reference
```

This keeps Persona or any similar vendor replaceable. The identity-proofing vendor contributes evidence. Phoros interprets that evidence within its own health-specific identity and authority architecture.

5.3 Combined Architecture

The relationship between the two provider categories and Phoros can be summarized as follows.



This separation preserves vendor flexibility. Keycloak or an alternative can be replaced without redefining Phoros identity. Persona or an alternative can be replaced without redefining legal identity semantics. The durable product logic lives in the Phoros identity and authority layer.

6 Recovery Is Not Merely Authentication Recovery

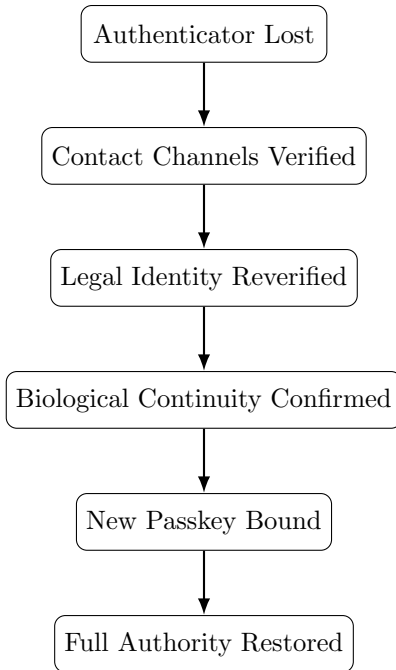
Consumer systems usually collapse recovery into email or phone reset. Phoros should not do this. Recovery should be separated into three distinct concepts.

Recovery Type	Question	Possible Outcome
Credential recovery	Can the user regain a login mechanism after losing a device or passkey?	New passkey enrolled; old credential revoked.
Continuity recovery	Is the same biological person present, or is continuity uncertain?	Continuity confirmed, uncertain, or conflicted.
Authority recovery	Who is allowed to exercise rights over the account and its health data?	Full authority restored, restricted authority restored, authority transferred, or manual adjudication required.

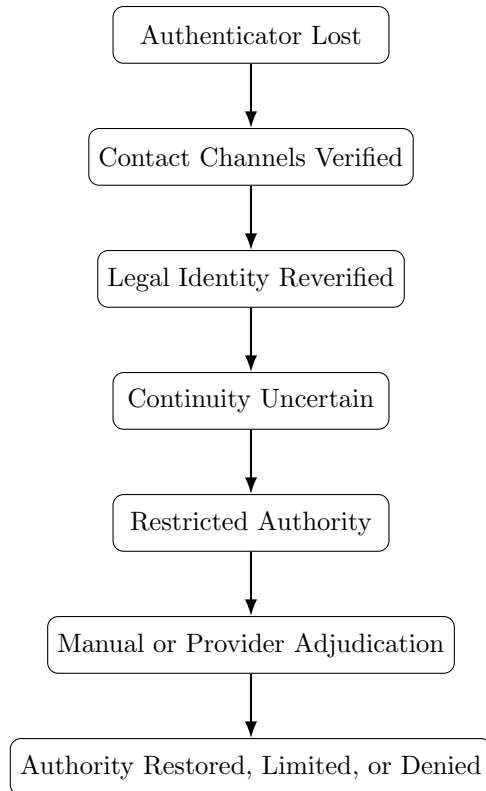
This distinction allows Phoros to restore login without automatically restoring full authority. For example, a user may regain access to a limited account interface while sensitive actions remain blocked until biological continuity or alternative high-assurance evidence is established.

7 Recovery State Transitions

A normal lost-device recovery path may look like this:



An uncertain recovery path should be different:



The important design rule is:

Restoring login is not equivalent to restoring full authority.

8 Authority Restrictions During Recovery

If credentials are lost, compromised, or continuity is uncertain, Phoros should allow a restricted state. In restricted authority, the user or claimant may be able to view limited account status or continue recovery, but should not be able to perform high-risk actions.

Examples of restricted actions include:

- exporting a complete longitudinal record;
- authorizing a data transaction;
- adding or removing a caregiver;
- changing legal representative settings;
- deleting biometric references;
- replacing recovery delegates;
- changing clinical identity bindings;
- revoking audit trails or provenance records.

Restricted authority is useful because it avoids two bad outcomes: immediate denial to legitimate users who fail an automated check, and immediate full control for attackers who happen to control an email account, phone number, or device.

9 Clinical Identity Binding

Clinical identity binding should be modeled separately from account activation. A user may have a valid Phoros account before connecting to a provider or importing records.

Clinical binding answers a different question:

Does this Phoros account correspond to a specific patient identity at a provider, payer, laboratory, imaging center, pharmacy, or other health-data source?

Possible evidence includes:

- provider-mediated attestation;
- patient portal connection;
- EHR export authorization;
- medical record number linkage;
- payer identity matching;
- lab or imaging account connection;
- signed clinical organization assertion.

This binding should also be provenance-bound. The system should record which institution made the assertion, when it was made, what identifiers were linked, what consent authorized the linkage, and whether the binding is active, superseded, revoked, or disputed.

10 Identity-Proofing Vendor Abstraction

Phoros should avoid hard-coding its architecture around a single identity- proofing vendor. Instead, it should define an internal interface for external identity assertions.

Conceptually:

```
IdentityProofingProvider
-> provider_name
-> workflow_id
-> asserted_attributes
-> evidence_types
-> verification_result
-> assurance_level
-> timestamp
-> expiration_policy
-> audit_reference
```

This allows Phoros to support vendors such as Persona, ID.me, Socure, Jumio, Entrust/Onfido, LexisNexis, or future government identity assertions without making any one of them the root of Phoros identity.

The architectural principle is:

External vendors provide identity evidence. Phoros owns the identity graph, consent state, recovery logic, biological-continuity model, and clinical binding model.

11 Implementation Notes

The backend should distinguish account status from authority status. For example:

AccountStatus:

```
Pending
ContactVerified
LegalIdentityVerified
Active
Suspended
Closed
```

AuthorityStatus:

```
None
Restricted
Full
Delegated
Transferred
Suspended
Disputed
```

Similarly, biometric references should not be silently overwritten. If a new biometric reference is created after injury, aging, device migration, or manual review, the system should treat this as a continuity event with its own provenance, not as a destructive update.

A minimal event vocabulary might include:

ContactChannelVerified
LegalIdentityAssertionReceived
PasskeyEnrolled
PasskeyRevoked
BiologicalReferenceCreated
BiologicalContinuityConfirmed
BiologicalContinuityUncertain
RecoveryPolicyConfigured
ClinicalIdentityLinked
AuthorityRestricted
AuthorityRestored
AuthorityTransferred

This event-centered structure makes onboarding and recovery auditable. It also supports future requirements around disputes, consent review, clinical record correction, caregiver access, and legal authority transitions.

12 Summary

Phoros onboarding is best understood as the staged construction of a high-assurance identity and authority substrate for patient-controlled health data. Email and phone verification establish contact-channel control. Legal identity proofing establishes external evidence about the applicant's legal identity. Passkeys establish cryptographic account control. Phoros liveness and biometric reference enrollment establish a biological-continuity anchor. Recovery policy setup defines how authority can be restored or transferred under uncertainty. Clinical identity binding then connects the active Phoros account to real healthcare records and institutions.

The central design constraint is that no single layer should be mistaken for the whole identity. Phoros should preserve the distinction between login, legal identity, biological continuity, clinical identity, and authority over health data.